

Designing and Evaluating a Retrieval-Augmented Generation System for Cybersecurity Practitioner Guideline Generation

Assignment 3 — Research and Mini Project
Course: Advanced Topics in Artificial Intelligence

Student: Christo Joshy (a1962973)

Year: 2026

Abstract

This paper introduces the design, development, and assessment of a Retrieval-Augmented Generation (RAG) system to generate cybersecurity practitioner guidelines. The MITRE ATT&CK Enterprise Framework is expanded to create a 2,578-sample knowledge base by breaking 697 adversary techniques down into multi-angle question-answer pairs. Dense retrieval is done by loading the all-MiniLM-L6-v2 sentence embedding model into a FAISS. Three structured practitioner guidelines are produced by the Zephyr-7B-beta instruction-tuned language model, loaded under 4-bit NF4 quantisation, for every query based on the retrieved context. The usage of an intermediate TF-IDF prototype for the final dense architecture is justified. Evaluation uses a reference free framework for computing Context based on RAGAS format.

Relevance, Answer Relevance and Faithfulness with embedding cosine similarity. Ten queries give Context Relevance 0.5610, Answer Relevance 0.5217 and Faithfulness 0.4885 when aggregating results. The retrieval cosine score showed a near perfect correlation with the context relevance ($r = 0.9491$) confirming that the quality of retrieval is the most important factor for the downstream performance of the pipeline. The concept of limitations, ethical issues and governing suggestions are discussed.

Contents

1 Introduction	2
2 Literature Review	2
2.1 Retrieval-Augmented Generation	2
2.2 Dense Passage Retrieval	3
2.3 Sentence Embeddings	3
2.4 Efficient Similarity Search	3
2.5 Quantisation for Efficient LLM Deployment	3
2.6 Instruction-Tuned Language Models	3
2.7 RAG Evaluation	4
3 Methodology	4
3.1 Knowledge Base Construction	Error! Bookmark not defined.
3.2 Text Preprocessing and Chunking	Error! Bookmark not defined.
3.3 Models	Error! Bookmark not defined.
3.5 Hyperparameter Configuration	5
3.6 Evaluation Metrics	6
4 Experimental Results	6
4.1 Intermediate Prototype: TF-IDF Retrieval	6
4.2 Final System: Dense Retrieval Evaluation	7
4.3 Generation Results	7
4.4 RAGAS-Style Evaluation	8
4.5 Key Findings	9
5 Limitations and Error Analysis	9
6 Ethical Considerations and Governance	10
7 Conclusion	10
References	11

1 Introduction

LLMs can generate plausible but unconfirmed output when asked about specialized topics like cybersecurity, trained on general corpora. A practitioner who needs advice on privilege escalation mitigations needs to be given advice based on authoritative, up-to-date information, not the statistical characteristics of web text. To address this issue the Retrieval-Augmented Generation integrates a LLM along with a retrieval module which can retrieve the relevant documents during inference and thus helps in conditioning the generation on verified external evidence .

This project extends RAG to the cyber security field, focusing on the creation of high-level, actionable practitioner guidelines based on the MITRE ATT&CK Enterprise Framework, the world's leading structured adversary knowledge base, adopted by governments, security vendors and researchers globally Strom et al. (2018). This system is tested with 3 RAGAS-style metrics Es et al. (2023) without any annotations or external API keys.

Research Questions

1. Is dense embedding-based retrieval able to get more semantically relevant results than TF-IDF sparse retrieval for cybersecurity domain queries?
2. Is it possible to get a coherent, actionable practitioner guidelines from an LLM, with instruction tuning and a 4-bit-quantization, from retrieved MITRE ATT&CK context on a T4 GPU?
3. What are the relationships between the retrieval quality and the quality of the downstream generation (RAGAS-style)? What are the major constraints and ethical concerns with using a RAG system to create cybersecurity guidelines in the operational environment?

2 Literature Review

2.1 Retrieval-Augmented Generation

RAG combines a dense passage retriever with a sequence-to-sequence generator in a joint architecture. The main advantage is to have knowledge retrieval as a separate parameterization from knowledge generation, thereby decreasing hallucination in knowledge-intensive tasks. Their work highlighted the ability of their model to perform well on open domain question answering and fact verification tasks, which inspired the architecture used in this work, which was pre-trained without task-specific data.

2.2 Dense Passage Retrieval

showed that the bi-encoder dense retrieval with BERT based encoders substantially outperforms sparse BM25 retrieval in open-domain question answering. In dense retrieval, both the queries and documents are embedded into a common vector space, allowing to search using the semantic similarity. This is an important property for cybersecurity queries that ask practitioners to formulate questions in natural language that do not necessarily contain the vocabulary typically used in technical descriptions of techniques — property that has been empirically confirmed in this project by the TF-IDF intermediate prototype.

2.3 Sentence Embeddings

Reimers and Gurevych (2019) extended BERT by adding a siamese network architecture to it thus finding a new model named Sentence-BERT. This is an all-MiniLM-L6-v2 model with 22.7M parameters producing 384-dimensions of embeddings, which performs well on the MTEB retrieval benchmarks with moderate computational cost for a T4 GPU deployment.

2.4 Efficient Similarity Search

The IndexFlatIP index supports exact inner product search with little latency, and is suitable for use at the corpus level (2578 vectors). L2 normalising embeddings before indexing makes inner product search equivalent to cosine similarity.

2.5 Quantisation for Efficient LLM Deployment

The 4-bit NF4 quantisation achieves the same model quality as full float16 precision, but uses about 75% less of the GPU memory. Unlike standard INT4, NF4 is specially tailored for the approximately normally distributed weight matrices of transformer models, which, accordingly, reduces the quantisation error. This allows the 7-billion parameter Zephyr model to be run on the T4 GPU using around 5GB VRAM.

2.6 Instruction-Tuned Language Models

Zephyr-7B-beta is an updated version of Mistral-7B that was fine-tuned using Direct Preference Optimisation (DPO) by Tunstall et al. (2023). In contrast to PPO-based RLHF, DPO does not require a separate reward model and lowers the GPU memory usage and training instabilities. The resulting model exhibits good instruction-following, critical for the ability to produce succinct numbered instructions, rather than unrestrained continuations.

2.7 RAG Evaluation

It is a type of evaluation method which uses relevance, answer relevance, and faithfulness. The initial version comes with an API key for entailment checking with the LLM. This project adopts an embedding cosine similarity approximation, similar to that of who prove that embedding-based evaluation holds high correlation with LLM-based evaluation scores.

3 Methodology

3.1 Knowledge Base Construction

The knowledge base comes from the MITRE ATT&CK Enterprise Framework (which is also available as a STIX 2.0 JSON file from the official MITRE CTI GitHub repository). Attack-patterns are extracted as techniques, and deprecated and revoked are dropped. To determine mitigation descriptions, a STIX relationship object is traversed that connects a technique identifier to course-of-action objects.

For each of the 697 valid techniques, the technique is expanded into a series of up to five question-answer pairs that explain various aspects of the practitioner's information needs: (1) what the technique is, (2) which ATT&CK tactic the technique is part of, (3) how defenders can detect the technique, (4) which mitigations are recommended, and (5) which platforms does the technique affect. An expansion across multiple angles makes it possible to present the retrieval system with content relevant to a query, no matter how it was formulated by the practitioner. The final knowledge base has 2,578 deduplicated and shuffled samples. The composition of the knowledge base has been provided in Table 1.

Table 1: Knowledge base composition

Difficulty	Count	Percentage
Basic	1,344	52.1%
Intermediate	672	26.1%
Advanced	562	21.8%
Total	2,578	100%

3.2 Text Preprocessing and Chunking

Raw MITRE descriptions are HTML marked and cite marked. These are eliminated by a pre-processing pipeline based on regular expressions and removing spaces. The questions and answers are joined together into one document string, in the following format: Answer: {a} for the question {q} which is represented in a unified semantic context in the embedding model. Using the cl100k BPE tokeniser, a sliding window chunker is used to divide each document into chunks of 256 tokens, overlapping by 32 tokens. There are 104 tokens on the average pair, so each document is in a single chunk and there are 2,578 chunks without splitting. The following table shows the results of the different chunking configurations and outcomes.

Table 2: Chunking configuration and outcomes

Parameter	Value
Chunk size (tokens)	256
Overlap (tokens)	32
Total chunks	2,578
Average tokens / chunk	104.2
Min tokens	31
Max tokens	212
Chunks requiring split	0

3.3 Models

Embedding model. all-MiniLM-L6-v2 with 22.7M parameters produces 384-dimensional unit vectors. The encoding GPU (T4) uses a batch of 128. Vectors are stored in a FAISS IndexFlatIP store, and then indexed in an IndexIDMap, which is used to get metadata information. An exact search is very simple for 2,578 vectors, and was deemed important for not introducing approximation error, which is why indexFlatIP was chosen over approximate indices.

Generation model. HuggingFaceH4/zephyr-7b-beta has been loaded with 4-bit NF4 quantisation, float16 compute dtype and double quantisation Dettmers et al. (2023). With this setup the model consumes about 5 GB of the T4's 14.6 GB VRAM. Zephyr-7B-beta chose to be the base on which DPO fine-tuned because, unlike PPO-based RLHF, it doesn't require using four models for access and the published model is under the MIT licence.

3.4 Pipeline Overview

The whole pipeline is extended as follows: All-MiniLM-L6-v2 is used to encode a practitioner query into a 384-dimensional unit vector. (3) FAISS IndexFlatIP returns the most similar (by cosine similarity) top-3 chunks. (3) Zephyr is fed a prompt (using its ChatML template) that contains only the provided context, and generates only three numbered guidelines, then the three retrieved chunks and the query. Zephyr-7B produces up to 300 tokens per generation at a temperature of 0.3, top-p of 0.9 and repetition penalty of 1.1. These are three RAGAS-style metrics that are calculated after generation.

3.5 Hyperparameter Configuration

Table 3: Hyperparameter configuration

Component	Parameter	Value
Embedding	Model	all-MiniLM-L6-v2
	Embedding dim	384

	Batch size	128
	Normalisation	L2 (enabled)
Index	Type	FAISS IndexFlatIP
	Top-k	3
LLM	Model	zephyr-7b-beta
	Quantisation	4-bit NF4
	Temperature	0.3
	Top-p	0.9
	Repetition penalty	1.1
	Max new tokens	300
Chunking	Chunk size	256 tokens
	Overlap	32 tokens

3.6 Evaluation Metrics

Three embedding cosine-similarity based RAGAS-style metrics are calculated without any human annotations or API keys..

Context Relevance (CR): Each of the $k = 3$ chunk vectors retrieved, c_i , is compared to the query vector, q , using mean cosine similarity.

Answer Relevance (AR): Cosine similarity between generated answer vector a and query vector q .

$$AR = \cos(q, a).$$

Faithfulness (F): Average of cosine-similarity of the maximum score of each answer sentence s with all retrieved sentences.

Two separate metrics for retrieval quality are used: Hit Rate at 3 and Mean Reciprocal Rank.

4 Experimental Results

4.1 Intermediate Prototype: TF-IDF Retrieval

This is a pilot study of TF-IDF retrieval. This is an intermediate prototype of TF-IDF retrieval. An intermediate prototype was implemented on a 500-sample subset that uses the TF-IDF sparse retrieval with bigram features to get a baseline for the final dense

architecture and to provide justification. The Hit Rate (0.90) seems sufficient but the mean cosine score (0.1645) indicates a fundamental limitation: TF-IDF cosine similarities are not meaningful in a real system with a threshold for confidence to set. Also, the phishing query got the highest result in the Wi-Fi Networks technique (T1204) because of the common words used about “initial access” without the understanding of those words semantically. The mismatch between vocabulary and text was the reason to switch to dense retrieval.

Table 4: TF-IDF intermediate prototype evaluation

Metric	Value
Hit Rate @ 3	0.90 (9/10)
MRR @ 3	0.85
Mean Top-1 Score	0.1645
Corpus size	500 samples

4.2 Final System: Dense Retrieval Evaluation

The final system is a dense retrieval system, which is evaluated in 4.2. The system was evaluated using 10 practitioner queries with 2,578 samples in the final system, using FAISS dense retrieval. Table 5 shows results per query. The following table shows the retrieval results from the last dense system. The final dense system retrieval results are shown below in Table 5.

Table 5: Per-query retrieval results — final dense system

Q	Query (abbreviated)	Hit@3	MRR	Top Score
1	Phishing initial access	1	0.50	0.5096
2	Privilege escalation (Windows)	1	1.00	0.7196
3	Lateral movement	1	1.00	0.5576
4	Data exfiltration	1	1.00	0.5277
5	Persistence techniques	1	1.00	0.6449
6	Credential dumping	1	1.00	0.7030
7	Antivirus evasion	1	1.00	0.5543
8	Command and control	1	1.00	0.5800
9	Web application exploitation	1	1.00	0.5917
10	Reconnaissance	1	0.00	0.5263
Aggregate		9/10	0.85	0.5815

4.3 Generation Results

The ten queries were all run through the entire pipeline: top-3 chunks retrieved, prompt construction (mean 605 tokens), and Zephyr-7B guideline generation. There were only three practitioner guidelines in total, and all of them were found with all ten queries.

Table 6: Example generated guidelines for Query 2 — privilege escalation on Windows

Retrieved	T1068 (score: 0.72), T1068 (score: 0.71), T1548 (score: 0.63)
Guideline 1	regularly audit and control user accounts for proper permissions. Use the principle of least privilege, only giving administration privileges as needed for specific tasks.
Guideline 2	Avoid installing or running software that is not recommended by the guidelines to limit the possibility of malware being installed and obtaining higher privilege.
Guideline 3	AppLocker can be enabled and configured to specify what applications are allowed to run and to prevent unauthorized executables from being run, which will reduce the attack surface for privilege escalation (Guideline 3).

4.4 RAGAS-Style Evaluation

Per-query scores and statistics for the RAGAS style metrics is shown in Table 7. The result of the evaluation carried out according to the RAGAS-style format is shown in Table 7 below. Evaluation results in the RAGAS-style format are shown in Table 7 below)

Q	Query (abbreviated)	CR	AR	F
1	Phishing initial access	0.4915	0.4951	0.4630
2	Privilege escalation (Windows)	0.6857	0.6750	0.4594
3	Lateral movement	0.5450	0.3773	0.3587
4	Data exfiltration	0.5088	0.5278	0.6631
5	Persistence techniques	0.5590	0.4295	0.5095
6	Credential dumping	0.6401	0.6726	0.4663
7	Antivirus evasion	0.5466	0.5979	0.5021
8	Command and control	0.5681	0.5239	0.4776
9	Web application exploitation	0.5661	0.5563	0.4521
10	Reconnaissance	0.4992	0.3615	0.5328
Mean		0.5610	0.5217	0.4885
Std		0.0612	0.1101	0.0770
Min		0.4915	0.3615	0.3587
Max		0.6857	0.6750	0.6631

4.5 Key Findings

Finding 1: Retrieval leads to down stream performance. The Pearson correlation analysis for retrieval cosine score and the quality of the output in terms of the relevance to context is $r = 0.9491$, which verifies that retrieval is the main factor influencing the quality of the output. As for faithfulness, the correlation is negative ($r = -0.2534$), which means that the LLM is not doing so despite higher retrieval confidence.

Finding 2 – The specificity of the query is important to performance. Query number 2 and 6 (privilege escalation and credential dumping) are highest of all three metrics as they align to the two clearly defined categories of MITRE techniques and generate a high number of retrievals with a high level of confidence, and generate a high number of queries focused on the technique. Queries 3 and 10 (lateral movement and reconnaissance) have the lowest scores due to the fact that these general concept questions bring up parts of the answer that are relevant to several of the technique categories. Results: Dense retrieval significantly outperforms sparse retrieval

Finding 3. Intermediate TF-IDF prototype gave poor confidence scores (mean 0.1645) and did not semantically relate the queries with the technique descriptions because of the occurrence of vocabulary mismatch. The final dense system obtains the mean cosine scores of 0.5610 which is about $3.4\times$ higher than the baseline, and has meaningful semantic discrimination between relevant and irrelevant chunks.

Finding 4 - The main limitation of the system is that it fails to be faithful. Overall, the mean faithfulness score is 0.4885, suggesting that many of the sentences generated are not completely faithful. This behaviour is in line with that of decoder-only instruction models that add plausible but unconfirmed parametric knowledge Es et al. (2023).

Limitations and Error Analysis

Retrieval errors. The false positive in Query 1 (phishing) was caused by the Wi-Fi Networks technique (T1669) being more prevalent and catching more than Phishing (T1566). Both are “initial access” techniques and that's why it ranked higher. This proves that the single-stage bi-encoder retrieval without cross-encoder reranking is known to suffer from this shortcoming. A hybrid BM25 + dense approach or a cross-encoder reranker would decrease these errors, but would not be considered as it would not be feasible to use on the T4 GPU.

Faithfulness and hallucination. The "faithfulness" was lower than 0.50 on 6 of 10 queries. For instance, if the MITRE-chunks retrieved by Query 8 (command and control) do not mention “SAST tools” and “code review processes”, this is called hallucinated augmentation, since it is absent from the chunks but present in the generated guidelines. This is because the LLM uses parametric memory when it can't retrieve all the information required to answer the question.

Metric evaluation bias. This is because the same model, All-MiniLM-L6-v2, is used for query retrieval and computing metrics, which creates a circularity: The metric itself is giving positive feedback to the output semantically close in the retrieval model's

representation space. Stylistically, an incorrect sentence that is similar to a retrieved chunk would receive a very high score on faithfulness. However, to be able to evaluate the truthfulness of a statement it is necessary to perform natural language inference or entailment checking by an LLM (Question).

Knowledge base coverage. Only MITRE ATT&CK adversary techniques are covered in the corpus. The system is limited to compliance-oriented queries, as there are no defensive frameworks represented, such as NIST CSF, ISO 27001 or CIS Controls.

Future work. The addition of more embedding-based faithfulness scoring, expansion of the knowledge base with NIST and ISO 27001 defensive frameworks, and the replacement of embedding-based faithfulness scoring with LLM-based NLI would be a significant improvement.

5 Ethical Considerations

Dual-use risk. The retrieval part can return comprehensive details about the adversary's techniques, when the query is adversarial. To prevent misuse of production, query intent classification and output filtering layers are added to the production. Misinformation risk. The guidelines are laid out in a hierarchical and numbered order which can be misleading to users. If percentages of content are not grounded with 100%, then such low scores as less than 0.50 indicate that a large percentage of the content generated is not well supported. All deployments should include source citations, prominent disclaimers and human expert review prior to implementing guidelines in decisions that impact security.

Bias. The MITRE ATT&CK corpus contains adversary behaviours that are primarily from the Western security vendors and government agencies, leaving some adversary techniques out of the scope of its current documentation that are more common in different geopolitical environments. The Zephyr-7B model also shows instruction bias, suggesting that patch management and multi-factor authentication are over-represented amongst the controls in its DPO training set, as it continues to suggest both of these controls, no matter the query context.

Governance. To promote responsible usage: (1) have a model card with limitations and evaluation outcomes; (2) use version-control for the knowledge base snapshot and re-index the knowledge base after every release of MITRE ATT&CK; (3) apply the NIST AI Risk Management Framework, and consider a system that generates security-critical recommendations as a high-risk system, as per the EU AI Act; (4) add a faithfulness threshold and include analyst escalation for low-confidence output..

6 Conclusion

This project has demonstrated and tested a full RAG pipeline for generating cybersecurity practitioner guidelines. The evaluation is performed on three reference-free RAGAS-style

metrics and comprises a 2,578-sample MITRE ATT&CK knowledge base, a 4-bit quantised Zephyr-7B instruction tuned generator and a dense retrieval model that uses sentence embeddings from FAISS. To validate this decision, an intermediate TFIDF prototype was developed and tested empirically, which empirically validated the need to switch to dense retrieval, by showing the vocabulary mismatch problem that cannot be solved by sparse retrieval. For RAGAS style evaluation, across 10 practitioner queries, the Context Relevance is 0.5610, Answer Relevance is 0.5217 and Faithfulness is 0.4885. As shown in the table below, there is an almost perfect correlation between retrieval score and context relevance ($r = 0.9491$), thus proving that the quality of retrieval is the most important factor in pipeline performance. The least potent measure of fidelity is the one that is known to be followed by decoder-only instruction models: Faithfulness. The system shows that RAG can yield faithful outputs from the LLM when the underlying knowledge is authoritative in the cybersecurity domain, but with the help of appropriate governance, it can be deployed and produced in the future.

GitHub Repository: <https://github.com/christo08-eng/Advanced-Topics-in-AI-Assignment3>

References

- Dettmers, T., Pagnoni, A., Holtzman, A. and Zettlemoyer, L. (2023) 'QLoRA: Efficient finetuning of quantized LLMs', *Advances in Neural Information Processing Systems*, 36, pp. 10088–10115.
- Es, S., James, J., Espinosa-Anke, L. and Schockaert, S. (2023) 'RAGAS: Automated evaluation of retrieval augmented generation', *arXiv preprint arXiv:2309.15217*. Available at: <https://arxiv.org/abs/2309.15217>
- Johnson, J., Douze, M. and Jégou, H. (2021) 'Billion-scale similarity search with GPUs', *IEEE Transactions on Big Data*, 7(3), pp. 535–547.
- Karpukhin, V., Oguz, B., Min, S., Lewis, P., Wu, L., Edunov, S., Chen, D. and Yih, W. (2020) 'Dense passage retrieval for open-domain question answering', *Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pp. 6769–6781.
- Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Ku"ttler, H., Lewis, M., Yih, W., Rocktaschel, T., Riedel, S. and Kiela, D. (2020) 'Retrieval-augmented generation for knowledge-intensive NLP tasks', *Advances in Neural Information Processing Systems*, 33, pp. 9459–9474.
- Reimers, N. and Gurevych, I. (2019) 'Sentence-BERT: Sentence embeddings using Siamese BERT-networks', *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pp. 3982–3992
- Saad-Falcon, J., Khattab, O., Potts, C. and Zaharia, M. (2023) 'ARES: An automated evaluation framework for retrieval-augmented generation systems', *arXiv preprint arXiv:2311.09476*. Available at: <https://arxiv.org/abs/2311.09476>

- Strom, B.E., Applebaum, A., Miller, D.P., Nickels, K.C., Pennington, A.G. and Thomas, C.B. (2018) *MITRE ATT&CK: Design and philosophy*. MITRE Corporation Technical Report. Available at: <https://attack.mitre.org> .
- Tunstall, L., Beeching, E., Lambert, N., Rajani, N., Rasul, K., Belkada, Y., Huang, S., von Werra, L., Fourier, C., Lialin, N., Sanseviero, O., Romanou, A., Sanh, V., Sileo, D., Schulman, J., Wolf, T. and Rush, A.M. (2023) 'Zephyr: Direct distillation of LM alignment', *arXiv preprint arXiv:2310.16944*. Available at: <https://arxiv.org/abs/2310.16944> .